STUDENT GUIDE

Source-Grounded Research and Threat Intelligence

What an analyst needs to know before trusting a grounded answer about a threat

Session	AI + Cyber: AI Powered Cybersecurity, Session 3 of 5
Date	Friday, November 6, 2026
Author	Frazier A. Smith, Ed.D., Central Piedmont Community College
Companions	Participant Packet, Lab Manual, Session 3 Research Workbook
Version	1.0, November 6, 2026

How this guide differs from the packet. The Participant Packet tells you what to do this afternoon. This guide explains the ideas behind each step, with a numbered reference for every outside fact, so that you can hand it to a colleague or use it to build a lab of your own. Northbridge Technical College, GLASSFERN, and every organization in the Lab 5 evidence packet are fictional. The studies, standards, and the Ivanti Connect Secure case in Part 4 are real and dated. This guide does not discuss the Lab 5 sources one by one, so it is safe to read before the session.

This material is based upon work supported by the U.S. National Science Foundation under Grant No. 2300188. Any opinions, findings, and conclusions or recommendations expressed in this material are those of the author(s) and do not necessarily reflect the views of the National Science Foundation.

START HERE

How to Use This Guide

Session 2 asked whether an instructor can trust model output as evidence of student learning. Session 3 asks whether an analyst can trust model output as evidence about a threat. It also asks whether grounding the model in sources fixes the problem or only makes the answer look better supported. Lab 3 in Session 2 set the baseline: a well-prompted model invented an IP address that was not in the log it was given. Retrieval is the usual proposed repair, and this session tests it.

Part	Title	Read it when
1	Four Jobs and Retrieval-Augmented Generation	You need to say which job a tool performed, or explain what RAG is to a colleague
2	Why Threat Intelligence Fails Quietly	Someone proposes asking a chatbot about a current threat
3	What Grounding Fixes and What It Does Not	You are deciding how far to trust an answer that cites sources
4	Source Provenance, Dates, and Independence	You are weighing sources against each other, or counting how many sources support a claim
5	The Claim Ledger	You are recording research so that someone else can check it
6	Confidence and Likelihood	You are writing the bottom line of an assessment
7	Mapping to ATT&CK and ATLAS	You are tying reported behavior to a technique
8	Designing a Research Lab for Your Students	You are building Lab 6, or a research assignment of your own

The Argument in One Paragraph

A model answers from its training data unless something puts current text in front of it, and threat intelligence is almost entirely current text. Retrieval puts that text in front of the model, and the answer improves on one axis: it can now repeat what the sources say. Retrieval does nothing about whether the sources deserve to be repeated. A grounded answer can cite a passage that does not support the claim, summarize a stale or unsupported source faithfully, count five retellings of one report as five confirmations, and follow instructions hidden in a retrieved document. The defense is the analyst's discipline, applied to every claim that matters: open the source, check the passage, check the date, trace the claim to the first source that has its own evidence, and state confidence and likelihood separately. The tools speed up discovery and synthesis. Validation remains a human job.

Conventions

Numbers in brackets are references, listed at the end with URLs. Dates are publication dates unless the text names another kind of date, such as a revision date or a date added to a catalog. ATT&CK and ATLAS identifiers are given in full. Where this guide refers to the Session 1 or Session 2 Student Guide, it names the part or myth so that you can find it.

> The Lab 5 evidence packet is built to be worked, not read about. This guide teaches the checks. It does not say which packet sources pass them.

PART 1

Four Jobs and Retrieval-Augmented Generation

Research with AI tools involves four distinct jobs. Products blur them, and marketing blurs them further. An analyst who can name the job a tool performed can also name the job it did not perform.

Job	What it does	Examples in this session
Discovery	Finds candidate sources that might bear on a question	A web search engine; Perplexity; the archived discovery export in Lab 5
Retrieval	Selects passages from a fixed collection and places them in the model's context	The retrieval step inside NotebookLM, an Open WebUI knowledge collection, or the lab's `notebook.sh`
Synthesis	Writes an answer from the passages in context	The same three tools, after retrieval; Perplexity after its search
Validation	Checks that a passage supports a claim and that the source deserves the weight it is given	The primary-source lane in Lab 5, working with `less`, `grep`, and `pdftotext`. No tool in the room performs this job

What RAG Is

Retrieval-augmented generation (RAG) is the design that pairs a retriever with a text generator. The term comes from Lewis and colleagues, whose 2020 paper combined a pre-trained language model, which they called parametric memory, with a searchable index of documents, which they called non-parametric memory [1]. Parametric memory is what the model absorbed during training and stores in its weights. Non-parametric memory is a document collection the system can search at the moment of the question. The paper's motivation names the two problems this session cares about: pre-trained models struggle to provide provenance for their answers and to update what they know [1].

Current RAG products follow the same outline. The system splits each document into chunks, converts each chunk into a numeric vector that encodes its meaning, and stores the vectors in an index. When a question arrives, the system converts the question the same way, retrieves the chunks whose vectors sit closest to it, and pastes those chunks into the prompt. The model then writes an answer with the retrieved chunks in front of it, often with a citation to each chunk.

Three Places a RAG Answer Can Go Wrong

1. **Retrieval misses.** The passage that answers the question exists in the collection, but the retriever does not select it. The model answers from the chunks it did receive, or from training data.
2. **Synthesis drifts.** The right passage is in context, and the model still writes a claim the passage does not make. It may combine two passages, drop a qualifier, or fill a gap from training data.
3. **The collection is wrong.** Every step works as designed, and the answer faithfully repeats a source that is stale, unsupported, or hostile.

The first two failures are engineering problems and improve with better tools. The third is a sourcing problem, and no tool improvement addresses it. Part 3 returns to all three.

Open Web Versus a Bounded Notebook

A discovery tool with synthesis, such as Perplexity, searches the open web and writes an answer from whatever it found. Its collection is unbounded and changes from run to run. A bounded notebook, such as NotebookLM or `notebook.sh`, answers only from the sources you load. The bounded notebook is easier to audit, because you know exactly what was in its collection. It is also only as good as the sources you chose, and it adds a data question: whatever you load goes wherever the notebook runs. Under the Session 1 tier scheme, a Confidential log may go into a notebook on the campus server and may not go into a hosted tool.

PART 2

Why Threat Intelligence Fails Quietly

Threat intelligence is the worst case for a model answering from training data. The facts that matter are recent, specific, and identifier-heavy: a CVE number, an affected version range, a date added to a catalog, an IP range, a malware family name. A model produces all of these in the same fluent register it uses for facts it does know. Session 1's Myth 1 ("AI Knows the Latest Threats") and Myth 2 ("If It Gives a CVE Number, the CVE Is Real") made this point with tests. Part 2 adds the reasons.

The Training Cutoff

A model's parametric memory ends at its **training cutoff**, the date after which it saw no new text. OpenAI's model card for gpt-oss-20b, the large model on the lab server, states a knowledge cutoff of June 2024 [2]. Every vulnerability published after that date is unknown to the model unless an application supplies the text. CVE-2026-104935, the Ivanti Connect Secure flaw used in Demo 1 and in Part 4, was published on October 13, 2026 [9], twenty-eight months after the cutoff. Asked about it without the advisory, the model has two options: decline, or write a plausible description of a vulnerability it has never seen. Demo 1 shows which it chooses.

The Measured Case

Mezzi, Massacci, and Tuma tested three state-of-the-art models on cyber threat intelligence tasks using 350 threat intelligence reports [3]. Their evaluation measured accuracy, and it also measured consistency across runs and the confidence the models expressed. Their summary: the models "cannot guarantee sufficient performance on real-size reports while also being inconsistent and overconfident," and few-shot learning and fine-tuning "only partially improve the results" [3]. The study gave the models the reports. It measured extraction from text in context, which is the job retrieval is supposed to make reliable. The finding is that putting the source in front of the model does not, by itself, make the extraction trustworthy.

Confabulation

NIST AI 600-1 lists twelve risks specific to generative AI. The second is **confabulation**: "the production of confidently stated but erroneous or false content (known colloquially as 'hallucinations' or 'fabrications') by which users may be misled or deceived" [4]. The NIST term is useful in policy work because it places the problem in the output, not in the model's intent. A confabulated CVE description is produced by the same process as a correct one. Nothing in the text marks the difference.

Why the Failure Is Quiet

Three properties of threat intelligence work combine to hide errors.

- The reader usually cannot check the answer from memory. Few people know an affected version range by heart, which is why they asked.
- The errors are small and specific. A version number off by one release, a date off by a week, or an IP range attributed to the wrong actor reads as a detail, not as a mistake.
- The cost arrives later. A wrong fixed version leaves an appliance unpatched, and nobody learns of it until an incident.

The Session 2 baseline fits this pattern. The invented address in Lab 3 was one plausible indicator among several correct ones, and a rubric that scored structure and tone did not see it. Session 3 asks whether grounding catches that kind of error. Part 3 gives the answer: grounding catches some of it, and it introduces failures of its own.

PART 3

What Grounding Fixes and What It Does Not

Grounding means supplying the model with source text and instructing it to answer from that text. RAG is one way to ground a model. Pasting an advisory into the prompt, as Demo 1 does, is another. Grounding changes the question the model answers. Without grounding, the question is what a typical answer to the prompt looks like. With grounding, the question becomes what these passages say about the prompt.

What Grounding Fixes

A grounded answer can report facts newer than the training cutoff, provided the facts are in the supplied text. It can quote, and a quotation can be checked. It is also more likely to be silent about what the source omits, and silence is the correct answer to a question the source does not address. In Demo 1 the grounded answer is usually right about what the Ivanti advisory says and has nothing to say about what the advisory leaves out.

What Grounding Does Not Fix

Failure	What it looks like	The check that catches it
A citation that does not support its claim	The answer cites source 4 for a claim that source 4 states with a qualifier, states about a different product, or does not state at all	Open the cited passage and read it against the exact claim. A citation proves only that the source was in context
A faithful summary of a bad source	The answer accurately repeats a source that is out of date, that asserts without evidence, or that repeats another source	Evaluate the source itself: its date, its author, its evidence, and where it got its claim. Part 4
Repetition counted as corroboration	The answer says several sources agree, and every one of them traces to the same original report	Trace each claim to the earliest source with its own evidence and count origins, not citations. Part 4
Indirect prompt injection	A retrieved document contains text addressed to the AI system, and the answer follows it	Read sources before importing them; treat any instruction in a source as source content and log it

Indirect Prompt Injection

Greshake and colleagues named the last failure in February 2023. Their argument is that applications built around language models "blur the line between data and instructions" [5]. A user who asks a question supplies the instructions, and the retrieved documents supply the data. The model receives both in one stream of text, however, and an attacker who can place text in a document the system will retrieve can therefore issue instructions without ever touching the user's prompt. The authors demonstrated the attack against Bing's GPT-4 powered chat and against code-completion tools, and they wrote that "processing retrieved prompts can act as arbitrary code execution" [5]. MITRE ATLAS catalogs the technique as AML.T0051.001, LLM Prompt Injection: Indirect, and notes that the malicious prompts "may be hidden or obfuscated from the user" [7].

The production case is EchoLeak, CVE-2025-32711, which Microsoft released on June 11, 2025 with a CVSS base score of 9.3 and described as "AI command injection in M365 Copilot" that allowed an unauthorized attacker "to disclose information over a network" [6]. Session 1's guide describes the chain under Myth 8: a crafted email, once indexed, caused Copilot to retrieve the victim's own files and send their contents out through an image link. The victim did not need to open the email. The retrieval step that grounds the assistant also delivered the attack.

Handling Rules for Retrieved Content

- [ ] Read a source before it enters a notebook. A source nobody has opened is not imported.
- [ ] Text in a source that addresses an AI system, a reader's assistant, or "the model" is source content. Quote it in the ledger as evidence about the source. Never act on it.
- [ ] Check for hidden text in formats that can hold it: white or tiny text in a PDF, HTML comments, alternate text, metadata fields. `pdftotext` and `grep` show text a viewer hides.
- [ ] When a source carrying an instruction has already been in a notebook's context, re-run the main question without it and record what changed. Log the exposure in the Evidence Log.
- [ ] Never visit, download from, or run anything at a link that a retrieved instruction recommends.

PART 4

Source Provenance, Dates, and Independence

Provenance is the record of where a piece of information came from: who observed it, who wrote it down, and who repeated it afterward. ICD 203, the analytic standards directive for the U.S. intelligence community, makes source description its first tradecraft standard. It lists the factors an analyst weighs: "accuracy and completeness, possible denial and deception, age and continued currency of information, and technical elements of collection as well as source access, validation, motivation, possible bias, or expertise" [14]. Those factors apply unchanged to a vendor blog or a news article.

Source Types

Type	Definition	What it can establish
Primary observation	Data the analyst's own organization collected: logs, alerts, packet captures	What happened on your systems. It cannot establish who did it or why
Primary research	A firm or researcher reporting its own investigation, with method and evidence	What that investigator saw, at the sites it investigated
Vendor advisory or telemetry	A product vendor describing its own product, or what it saw across its customers	Affected and fixed versions; patterns across the vendor's customer base. The vendor has a stake in the framing
Authoritative record	A catalog entry with a defined scope: a CVE record, the NVD, the CISA Known Exploited Vulnerabilities (KEV) catalog	The fact the catalog exists to record, such as an identifier, a description, or a date added. Anything outside that scope is out of scope
Secondary report	News, newsletters, provider briefs, and aggregators that report what others found	That a claim exists and where it came from. A secondary report adds no evidence of its own

Which Date Counts

A web page carries several dates, and only one of them dates the information. The **content date** is the date the author wrote or last revised the text. A crawl date, an indexing date, a republication date, and the date at the top of an aggregator's page are not content dates. Republished content often shows the newest date most prominently. For the ledger, record the content date and the revision, if the source has one. When a source has been revised, the revision is the current position of its author, and the earlier version is evidence of what the author used to think.

Independent Corroboration Versus Repetition

Two sources corroborate each other independently only when each has its own access to the facts. A news story that cites a blog post is not a second observation of what the blog post reports. Neither is a newsletter that cites the news story. Five documents in that chain hold one observation. The test is to trace each claim backward through every citation until it reaches a source that claims its own evidence, and then to count those origins.

Repetition does more than inflate a count. Each retelling is a chance for the claim to change. Qualifiers drop out first: an estimate becomes a count, a possibility becomes a finding, and a vendor's stated uncertainty disappears. The reliable check is to compare each retelling's wording with the origin's. When a later source states a claim more strongly than its origin, the strengthening came from the retelling, not from new evidence.

A trusted domain does not repair a page with no source. Government, university, and established-vendor domains publish well-sourced material most of the time, and that is what makes an unsourced page on the same domain persuasive. Judge the page by its own evidence. Its address counts only after that test.

A Worked Case: CVE-2026-104935 in Six Sources

Ivanti Connect Secure (ICS) is an SSL VPN appliance that many colleges run. On October 13, 2026, Ivanti disclosed CVE-2026-104935, an authentication bypass by spoofing that lets a remote, unauthenticated attacker execute arbitrary commands [9, 11]. CISA added it to the KEV catalog the same day [8]. Six public sources describe it, and each has a different author, scope, and date. Demo 1 uses this case, and the files are in `/opt/nitic/session3/demo_cve` on the range. All of them are public tier.

Source	Author and type	Date	Scope: what it exists to say
KEV entry [8]	CISA; authoritative record	Added Oct 13, 2026; due Oct 16, 2026	That CISA lists the flaw as exploited, the required action, and the due date. It does not list versions
CVE record [9]	Ivanti as CVE Numbering Authority; authoritative record	Published Oct 13, 2026, 15:31 UTC	One identifier, one description, a CVSS 3.1 score of 8.6, and structured version data
NVD entry [10]	NIST; authoritative record	Published Oct 13, 2026; status Analyzed	The CNA description repeated, with NVD's analysis added. The description is the same text as the CVE record
Vendor advisory [11]	Ivanti; vendor advisory	Created Oct 13, 2026; modified Oct 29, 2026	Three chained CVEs, with affected and resolved versions given separately for each
CISA alert [12]	CISA; government alert	Oct 13, 2026; revised Oct 30, 2026	All three CVEs together, the versions affected by any of them, and recovery steps
Volexity blog [13]	Volexity; primary research	Oct 13, 2026	One investigation, begun October 5, at one customer whose appliance ran 22.8R2.4; the exploit chain and the attacker's actions afterward

Where the Sources Disagree

The affected versions. The CVE record's description says the flaw affects "ICS before version 25.1.3.0" [9]. Its structured data marks 25.1.3.0, 25.1.3.1, 22.8R2.5, and 22.7R2.14 as unaffected and every other version as affected by default. Read literally, version 25.1.1.2 is affected. The advisory's table lists 25.1.1.2 as a resolved version for this CVE [11]. The CISA alert, as revised October 30, lists "versions 25.1.1.2 and prior, 25.1.2.2 and prior, and 22.8R2.5 and prior" [12]. Its range is wider because it covers all three chained CVEs, and two of them were fixed only in 25.1.1.3 and 22.8R2.6 [11].

None of the three is wrong. The CVE record describes one identifier, written on disclosure day. The advisory gives the vendor's version table for each CVE separately. The alert answers a different question: which appliances need attention because of the whole chain. A ledger row that says "25.1.1.2 is vulnerable" is true for the chain and false for CVE-2026-104935 alone. The row needs the source, the passage, and the scope, or it will be read as a contradiction when it is a difference in scope.

A broken link in an authoritative record. The KEV entry's notes field points to `https:/forums.ivanti.com/s/article/Security-Advisory-Ivanti-Connect-Secure-CVE-2026-104935` [8]. The address has one slash after the scheme, so the link fails as written, and it names a different Ivanti host than the CVE record does. Authoritative records are maintained by people. Check that each link resolves to the document it claims to be.

Counting Independent Evidence in the Ivanti Case

Six documents describe CVE-2026-104935. Counting the observations behind them is the exercise Lab 5 asks you to perform on a different question.

Claim	Sources that state it	Origins with their own evidence
The flaw exists and is fixed in specific versions	CVE record, NVD, advisory, alert	One: Ivanti. The CVE record is Ivanti's text, the NVD repeats it, and the alert points readers to the advisory
Attackers exploited it before a patch existed	Advisory, alert, KEV entry, Volexity	Volexity's investigation, which reports exploitation starting October 3, 2026 [13]. Ivanti reports exploitation affecting "a limited number of customers" [11] and also states that it "collaborated with Volexity on their blog post." CISA states that it is aware of exploitation and does not publish its basis [12]
The attacker sprayed passwords and harvested credentials after entry	Volexity	One investigation at one customer. No other source in the set repeats or confirms it

The count for exploitation is at least one and at most three. Volexity's evidence is described in detail. Ivanti's evidence is its own customer reports, but its statement was coordinated with Volexity. CISA's evidence may be independent, and its alert does not say. A careful ledger records that uncertainty instead of writing "confirmed by four sources." The KEV listing records CISA's determination that the flaw is being exploited. It is not a fourth independent account of what the attacker did.

The case also shows how dates interact with scope. The CISA alert and the Ivanti advisory were both revised after October 13. A model given only the October 13 versions would report the narrower picture with full confidence. A student who saved the links in prework and opened them today would see the revisions. The content date and the revision date belong in the ledger for that reason.

Questions to Ask Every Source

1. Who wrote it, and what access did that author have to the facts?
2. When was the content written or last revised? Is that date in the body, the header, the footer, or nowhere?
3. What is the source's scope? What question does it exist to answer?
4. Where did the source get each claim that matters? Follow its citations until they stop.
5. Does the source state its claims more or less strongly than the source it cites?
6. Does the source contain anything addressed to a reader's tools rather than to the reader?

PART 5

The Claim Ledger

A **claim ledger** is a table with one row per consequential claim, recording where the claim came from and how far it can be trusted. A claim is consequential if it could appear in the brief or change the recommendation. The ledger is the research record. Anyone who reads it can find the passage behind each claim without asking the analyst.

Column	What to enter
Claim	One factual statement, in your own words
Source ID	One source per row. When a second source makes the same claim, it gets its own row
Passage	The exact words that support the claim, in quotation marks, with a location such as a heading, line, or page. Copy the passage from the file, never from a model's answer
Source type	Primary observation, primary research, vendor advisory or telemetry, authoritative record, or one of the secondary types
Date	The content date. Not the crawl, index, or republication date
Independent support	The other sources that support the claim on their own evidence, and a verdict from whoever opened the passage: supported, partly supported, or not supported
Confidence	High, moderate, or low, for this row
Correction	Any later change to the row, with the time and the reason

Three Rows From the Ivanti Case

Claim	Source	Passage	Type, date	Independent support	Conf.
ICS 25.1.1.2 is not affected by CVE-2026-104935	Ivanti advisory	Affected Versions table, row CVE-2026-104935, Resolved Version(s): "25.1.1.2"	Vendor advisory, Oct 13, 2026, rev. Oct 29	None independent. The CVE record's description reads as if 25.1.1.2 were affected; scope differs. Supported	High
ICS 25.1.1.2 needs updating because of the chained CVEs	CISA alert	"affecting Ivanti Connect Secure versions 25.1.1.2 and prior"	Government alert, Oct 13, 2026, rev. Oct 30	Ivanti advisory, row for CVE-2026-111357 and CVE-2026-118527. Supported	High
Exploitation began by October 3, 2026	Volexity blog	Analysis section: "starting on October 3, 2026, UTA0576 repeatedly exploited these vulnerabilities"	Primary research, Oct 13, 2026	None. One investigation. Supported as Volexity's finding	Moderate

The first two rows look contradictory until the scope is written down. The third row is well supported as a statement about what Volexity found, and only moderately reliable as a statement about when the campaign began, because one investigator saw one site.

Rules for the Ledger

- A row with no passage is a note, not evidence. It cannot support a sentence in the brief.
- Copy passages from the source file. A passage copied from a model's answer has not been checked, because the model may have paraphrased, merged, or invented it.
- Record corrections. A ledger that never changes after new evidence arrives is either complete by luck or has not been maintained.
- Lower a row's confidence when its only support traces back to one origin, however many documents repeat it.

PART 6

Confidence and Likelihood

An assessment makes two different statements about uncertainty, and ICD 203 requires that they be kept apart [14]. **Likelihood** is the probability that an event or development occurs. **Confidence** is the analyst's trust in the basis for the judgment. The directive says confidence "may be based on the logic and evidentiary base that underpin it, including the quantity and quality of source material, and their understanding of the topic" [14].

The ICD 203 Likelihood Terms

For likelihood, the directive requires one of two sets of terms, each tied to a probability range [14].

Term	Alternative term	Probability
almost no chance	remote	01 to 05 percent
very unlikely	highly improbable	05 to 20 percent
unlikely	improbable (improbably)	20 to 45 percent
roughly even chance	roughly even odds	45 to 55 percent
likely	probable (probably)	55 to 80 percent
very likely	highly probable	80 to 95 percent
almost certain(ly)	nearly certain	95 to 99 percent

The directive states that analysts "are strongly encouraged not to mix terms from different rows," and it requires a disclaimer when a product does [14]. It then states the rule this session enforces: products that use a confidence level "must not combine a confidence level and a degree of likelihood, which refers to an event or development, in the same sentence" [14].

Why the Two Must Stay Apart

The two measures vary independently. A judgment can be likely and held with low confidence, when thin evidence points one way. A judgment can be unlikely and held with high confidence, when strong evidence points away from the event. "We assess with high confidence that an attack is likely" fuses the two, and the reader cannot tell which part the evidence supports. Splitting the sentence forces the analyst to earn each half separately.

Fused	Separated
We are highly confident the VPN flaw will probably be exploited at colleges.	Exploitation of the VPN flaw against colleges that run unpatched appliances is likely (55 to 80 percent) within thirty days. We hold this judgment with moderate confidence, because the exploitation evidence comes from one detailed investigation and a vendor statement coordinated with it.

Both sentences concern a hypothetical vulnerability and show form only. Neither is an assessment of any real CVE.

Confidence Levels and the Brief

ICD 203 requires that confidence be stated and explained. It does not prescribe a scale. This track uses three levels, applied to ledger rows and to judgments in the brief.

Level	Use it when
High	Two or more independent origins with their own evidence agree, the sources are current, and no credible source contradicts them
Moderate	One credible origin with direct evidence, or several origins with gaps or minor conflicts
Low	The judgment rests on one origin with thin evidence, on repetition, on stale or unsupported sources, or on an inference the sources do not state

What the Brief Contains

ICD 203 also requires analysis of alternatives, which it defines as "the systematic evaluation of differing hypotheses to explain events or phenomena" [14]. The one-page brief in Lab 5 has seven parts: the bottom line; likelihood and confidence, in separate sentences; the key evidence, each item tied to a ledger row; the alternative explanations considered and why each was rejected or kept; limitations; collection gaps, meaning what you would need to know and could not find; and the recommendation, which must follow from the evidence as stated.

PART 7

Mapping to ATT&CK and ATLAS

MITRE ATT&CK catalogs adversary behavior against enterprise systems. MITRE ATLAS does the same for attacks on AI systems. A mapping ties a behavior described in a source to a technique identifier, so that defenders can compare reports and choose controls. A mapping is a claim, and it needs a passage like every other claim.

The Rule: Map From a Passage

CISA's guidance on ATT&CK mapping lays out six steps: find the behavior, research the behavior, identify the tactics, identify the techniques, identify the sub-techniques, and compare results with other analysts [15]. The first step is the one most often skipped. The behavior must be described in the source, in enough detail to distinguish one technique from its neighbors. Three practices follow.

1. **No technique from a headline.** "Hackers breach college accounts" supports no technique. It does not say how.
2. **Observed and reported are different.** A behavior in your own logs is observed. A behavior in someone else's report is reported, and the mapping inherits that source's confidence.
3. **A source's own technique table is the source's claim.** Record it as reported, and check the described behavior against the technique's definition before you repeat it.

Techniques You Are Likely to Consider

ID	Name	What a passage must show before you map it
T1110.003 [16]	Brute Force: Password Spraying	One password, or a small list of common passwords, tried against many accounts
T1621 [17]	Multi-Factor Authentication Request Generation	MFA requests generated to a user's device by someone attempting to complete a sign-in, in the hope that the user approves one
T1557 [18]	Adversary-in-the-Middle	The adversary positioned between the user and the service, such as a proxy that relays a real sign-in page
T1539 [19]	Steal Web Session Cookie	A session cookie stolen and reused to access a service as an authenticated user
T1566.002 [20]	Phishing: Spearphishing Link	A message carrying a link to adversary-controlled content
T1078 [21]	Valid Accounts	An adversary actually using the credentials of an existing account. An attempt to sign in is not use. The technique needs evidence that authentication succeeded
AML.T0051.001 [7]	LLM Prompt Injection: Indirect	Instructions placed in content that an AI system ingests from a separate channel, such as a document or web page

A Worked Mapping From the Volexity Report

Volexity lists the attacker's actions after entry, including "Password spraying" and a tool that searched Active Directory "via a compromised Active Directory service account" [13]. The first passage supports T1110.003, recorded as reported by Volexity at one customer, with no detail on targets or volume. The second supports T1078, because it states that the attacker used an existing account's credentials, recorded the same way. The report's account of an "authentication bypass" in the VPN appliance does not support T1078, because bypassing authentication is not the same as signing in with valid credentials. Each mapping goes in the ledger with its passage and two labels: observed or reported, and certain or uncertain. An entry such as "possibly T1557: the report mentions a proxy page but does not say it relayed the sign-in" is better than a confident technique ID with nothing behind it.

PART 8

Designing a Research Lab for Your Students

Lab 6 turns the Lab 5 workflow into an activity for your own course. The design problem is the same one Session 2 named for writing assignments. A research assignment that a model can complete without opening a source measures the model, not the student. The specification has seven parts, and each part closes one route around the research.

1. A Decision With Two Defensible Answers

A topic invites a summary. A decision forces the student to weigh evidence. "Should the department replace its VPN appliance this term or patch and keep it until the end-of-life date?" has two defensible answers, and the evidence decides between them. Name who the decision is for, because the audience sets the stakes.

2. The Corpus

Choose between current threat intelligence and a stable standards corpus. Current intelligence, such as a KEV entry and its advisories, is realistic and goes stale. Plan to refresh it each term, or freeze a dated snapshot and say so. A standards corpus, such as a NIST publication and a vendor hardening guide, changes slowly and still supports planted errors. State the data tier of every source, using your Session 1 matrix. Public sources may go into any tool. Anything above public tier stays on infrastructure the college controls.

3. A Planted Misleading Source

Type	How to build it	How a careful student detects it
Circular	A news item or newsletter that cites another source in the packet and states its claim more strongly	Follows the citation back and compares the wording with the origin
Stale	An older report republished with a recent crawl date at the top	Finds the content date and checks it against the question's time frame
Unsupported	A page on a credible-looking domain that asserts a number with no source or method	Asks where the number came from and finds no answer
Poisoned	A document with text addressed to AI tools, hidden or visible	Reads the extracted text before importing it and logs the instruction

Build planted sources from synthetic organizations and `.example` domains, as the Northbridge packet does, so that no real organization is misrepresented.

Scoring, Proof, and Peer Review

4. The Ledger Columns

Use the Part 5 columns or a subset. Keep at least the passage, the date, and independent support. Those three columns are the ones a model cannot complete without the source.

5. A Scoring Rule That Rewards Calibration and Correction

A rubric that scores only the conclusion rewards a confident guess. The default rule in this track awards points for each ledger correction a student makes after new evidence and deducts points for a high-confidence claim later shown to be unsupported. One workable version: one point per documented correction, up to three; minus two for each high-confidence row that the evidence does not support; full credit on the brief only when likelihood and confidence appear in separate sentences and each is justified.

6. Proof of Opening the Source

Require something a model cannot produce without the source in hand: a quoted passage with its page or line, a detail that appears only in the body of the document, or a file hash computed by the student. The Ivanti case offers an example. The KEV entry's malformed link is visible only to someone who opened the entry's notes field.

7. Peer Review

Before running the lab, have a colleague answer two questions in writing. Could a student complete this activity by asking a model, without opening a source? Which planted source would a careful student still miss?

Taking It Home

The Take-Home With Your Own Documents

Prework asked you to collect three public documents from your college and one KEV entry with its advisory and NVD page. Load the three college documents into a bounded notebook and ask five questions: two the documents answer, two they answer only in part, and one they do not address at all. Score each answer as supported, partly supported, or not supported by opening the cited passage. The fifth question tests whether the tool admits silence. Then repeat Demo 1 with your own CVE and compare both answers with the two facts you wrote down. Record every run in the Evidence Log, with the validation method and the verdict.

Running Lab 5 With Students

Lab 5 runs in a single long class or across two sessions. Keep the three lanes, and treat the primary-source lane as the senior role, not a fallback for students without accounts. Release new evidence partway through, because the correction column only matters when something changes. Have every team brief, and score likelihood and confidence separately. Students who have watched a well-sourced claim fall apart under tracing write the next ledger differently.

A Validation Checklist for Any Grounded Answer

- [ ] Each claim in the answer has a citation, and the cited passage, opened and read, states the claim with the same scope and strength.
- [ ] No identifier, version, date, or number appears in the answer that is absent from the sources in context.
- [ ] Each source's content date is known and fits the question's time frame.
- [ ] Each consequential claim has been traced to its origins, and the count of independent origins is recorded.
- [ ] No source in context contained an instruction to an AI system, or any such instruction has been quarantined, logged, and the answer re-run without it.
- [ ] No source above the tool's approved data tier was loaded.
- [ ] A named person accepted, revised, or rejected the answer, and the Evidence Log says which.

Items 2, 6, and 7 repeat Session 1's validation checklist. The rest are new for grounded answers.

What Session 4 Does With Today

Session 4 moves from reading about threats to analyzing scan output and telemetry inside an isolated range. One tool on the list is an agent that runs commands on its own. An agent that reads untrusted content and can act is the setting in which indirect prompt injection does the most damage. The handling rules in Part 3 become controls on what the agent may read and what it may do.

REFERENCE

Glossary

Term	Meaning as used in this session
Authoritative record	A catalog entry with a defined scope, such as a CVE record, an NVD entry, or a KEV entry. Authoritative within that scope only.
Bounded notebook	A synthesis tool that answers only from sources the user loads, such as NotebookLM or `notebook.sh`.
Circular reporting	A chain of sources that cite one another back to a single origin, so that repetition looks like corroboration.
Claim ledger	A table with one row per consequential claim: claim, source, passage, type, date, independent support, confidence, correction.
CNA	CVE Numbering Authority. An organization authorized to assign CVE identifiers and publish CVE records; often the product's vendor.
Confabulation	NIST's term in AI 600-1 for confidently stated but erroneous or false content from a generative model.
Confidence	The analyst's trust in the basis for a judgment, from the quantity and quality of the evidence. Stated separately from likelihood.
Content date	The date the author wrote or last revised a source's text. Not the crawl, index, or republication date.
Discovery	Finding candidate sources. A search engine performs discovery.
Grounding	Supplying source text to a model and instructing it to answer from that text.
Independent corroboration	Agreement between sources that each have their own access to the facts.
Indirect prompt injection	Instructions placed in content an AI system will retrieve, which the model may follow. ATLAS AML.T0051.001.
KEV catalog	CISA's Known Exploited Vulnerabilities catalog, which lists vulnerabilities known to be exploited, with a required action and a due date for each.
Likelihood	The probability that an event or development occurs, stated with the ICD 203 terms.
Non-parametric memory	A searchable document collection a system consults at question time. Lewis et al.'s term for the retrieval side of RAG.
Parametric memory	What a model absorbed in training and stores in its weights.
Provenance	The record of who observed a piece of information, who wrote it down, and who repeated it.
Retrieval	Selecting passages from a fixed collection and placing them in a model's context.
Retrieval-augmented generation (RAG)	A design that pairs a retriever with a text generator, so that answers are written from retrieved passages.
Scope	The question a source exists to answer. Two sources with different scopes can state different facts without either being wrong.
Synthesis	Writing an answer from passages in context.
Training cutoff	The date after which a model saw no new training text. June 2024 for gpt-oss-20b.
Validation	Checking that a passage supports a claim and that the source deserves its weight. A human job.

REFERENCE

References, 1 to 14

1	P. Lewis, E. Perez, A. Piktus, F. Petroni, V. Karpukhin, N. Goyal, H. Küttler, M. Lewis, W. Yih, T. Rocktäschel, S. Riedel, D. Kiela, "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks," NeurIPS 2020; arXiv:2005.11401, submitted May 22, 2020, revised Apr 12, 2021. https://arxiv.org/abs/2005.11401
2	OpenAI, "gpt-oss-120b and gpt-oss-20b Model Card," arXiv:2508.10925, Aug 8, 2025 (states a knowledge cutoff of June 2024). https://arxiv.org/abs/2508.10925
3	E. Mezzi, F. Massacci, K. Tuma, "Large Language Models Are Unreliable for Cyber Threat Intelligence," arXiv:2503.23175, submitted Mar 29, 2025, revised Nov 12, 2025. Session 1 reference 5. https://arxiv.org/abs/2503.23175
4	NIST AI 600-1, "Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile," July 2024, section 2.2, Confabulation. Session 1 reference 57. https://doi.org/10.6028/NIST.AI.600-1
5	K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, M. Fritz, "Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection," arXiv:2302.12173, submitted Feb 23, 2023, revised May 5, 2023. https://arxiv.org/abs/2302.12173
6	Microsoft Security Response Center, CVE-2025-32711, "M365 Copilot Information Disclosure Vulnerability," released June 11, 2025, CVSS base score 9.3; disclosed by Aim Security as EchoLeak. Session 1 reference 32. https://msrc.microsoft.com/update-guide/vulnerability/CVE-2025-32711
7	MITRE ATLAS, technique AML.T0051.001, LLM Prompt Injection: Indirect, created Oct 25, 2023; ATLAS data release 5.6.0. Browse at https://atlas.mitre.org/. https://github.com/mitre-atlas/atlas-data
8	CISA, Known Exploited Vulnerabilities Catalog, entry CVE-2026-104935 (Ivanti Connect Secure), date added Oct 13, 2026, due date Oct 16, 2026; catalog version 2026.11.04. https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-104935
9	CVE Program, CVE record CVE-2026-104935, assigned and published by Ivanti as CVE Numbering Authority, Oct 13, 2026. https://cveawg.mitre.org/api/cve/CVE-2026-104935
10	NIST National Vulnerability Database, CVE-2026-104935 detail, published Oct 13, 2026, status Analyzed. https://nvd.nist.gov/vuln/detail/CVE-2026-104935
11	Ivanti, "Security Advisory Ivanti Connect Secure (CVE-2026-104935)," article 000109571, created Oct 13, 2026, last modified Oct 29, 2026. https://hub.ivanti.com/s/article/Security-Advisory-Ivanti-Connect-Secure-CVE-2026-104935
12	CISA, "CISA Urges Patching Newly Exploited Vulnerabilities in Ivanti Connect Secure," alert, Oct 13, 2026, revised Oct 30, 2026. https://www.cisa.gov/news-events/alerts/2026/10/13/cisa-urges-patching-newly-exploited-vulnerabilities-ivanti-connect-secure
13	C. Gardner, S. Koessel, S. Adair, and Volexity Volcano Team, "A Series of Unauthenticated Events: Chained Exploitation of Ivanti Connect Secure Zero-Days," Volexity, Oct 13, 2026. https://www.volexity.com/blog/2026/10/13/a-series-of-unauthenticated-events-chained-exploitation-of-ivanti-connect-secure-zero-days/
14	Office of the Director of National Intelligence, Intelligence Community Directive 203, "Analytic Standards," signed Jan 2, 2015, with technical amendments signed Jan 21, 2022. https://www.dni.gov/files/documents/ICD/ICD-203.pdf

REFERENCE

References, 15 to 21

15	CISA, "Best Practices for MITRE ATT&CK Mapping," June 2021; CISA news release of Jan 17, 2023. https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping
16	MITRE ATT&CK Enterprise, T1110.003, Brute Force: Password Spraying. https://attack.mitre.org/techniques/T1110/003/
17	MITRE ATT&CK Enterprise, T1621, Multi-Factor Authentication Request Generation. https://attack.mitre.org/techniques/T1621/
18	MITRE ATT&CK Enterprise, T1557, Adversary-in-the-Middle. https://attack.mitre.org/techniques/T1557/
19	MITRE ATT&CK Enterprise, T1539, Steal Web Session Cookie. https://attack.mitre.org/techniques/T1539/
20	MITRE ATT&CK Enterprise, T1566.002, Phishing: Spearphishing Link. https://attack.mitre.org/techniques/T1566/002/
21	MITRE ATT&CK Enterprise, T1078, Valid Accounts. https://attack.mitre.org/techniques/T1078/

All URLs were checked on November 6, 2026. The CVE, NVD, KEV, CISA alert, Volexity, and Ivanti sources were also saved that day to `/opt/nitic/session3/demo_cve` on the range. The Ivanti advisory page renders in the browser, so the saved text copy is the one to quote from. Dates in the text are the dates the cited source was published, revised, or added to a catalog, as the text states. ATT&CK technique pages change between releases; the descriptions in Part 7 summarize the versions current on November 6, 2026.

This material is based upon work supported by the U.S. National Science Foundation under Grant No. 2300188. Any opinions, findings, and conclusions or recommendations expressed in this material are those of the author(s) and do not necessarily reflect the views of the National Science Foundation.